

Teste de Segurança

Autenticação, autorização, sessões, OWASP, testes de segurança Web e APIs.

Security Testing para QA

Security Testing busca identificar riscos que possam comprometer confidencialidade, integridade, disponibilidade e controle de acesso. QA pode incorporar verificações de segurança sem substituir especialistas de segurança.

Autenticação x autorização

Autenticação responde quem é o usuário; autorização define o que ele pode fazer. Testes devem cobrir credenciais, sessões, expiração, roles, permissões e tentativas de acesso indevido.

OWASP como referência

OWASP mantém materiais amplamente utilizados para riscos e testes de segurança web e API. Eles ajudam a estruturar checklists e aprofundamento técnico.

Inputs e validação

Campos, parâmetros, headers e payloads devem ser tratados como entrada não confiável. Validação, encoding e controles no servidor são importantes para reduzir classes de vulnerabilidade.

Sessões e tokens

Cookies, tokens, JWT e sessões precisam de expiração, proteção e invalidação adequadas. Logout, troca de senha e mudança de privilégio merecem cenários específicos.

API Security

Valide autenticação, autorização por objeto/função, rate limiting, exposição excessiva de dados, mensagens de erro e comportamento com payloads manipulados.

Ferramentas

OWASP ZAP pode apoiar análise dinâmica automatizada e manual. Burp Suite é amplamente utilizado para inspeção e testes de segurança. Ferramenta não substitui entendimento do risco.

DevSecOps e Shift Left

Segurança pode ser incorporada a requisitos, code review, análise de dependências, pipelines, testes e observabilidade. Quanto mais cedo um risco é identificado, mais opções existem para tratá-lo.

Dica de QA

Nunca use dados reais ou credenciais de produção em exemplos públicos de segurança.

Recursos oficiais

Site oficial: <https://wstg.owasp.org/>